Introduction à la blockchain

Cours de master – fondements, consensus, smart contracts et sécurité

M. Amine Bouchiha

Last updated: 29 octobre 2026

Plan du cours

1. Fondations : confiance, registres, taxonomie
2. Fondations cryptographiques
3. Structure des données et transactions
4. Consensus
5. Réseau et forks
6. Contrats intelligents et EVM
7. Sécurité et attaques
8. Passage à l'échelle et interopérabilité
9. Vie privée, régulation, gouvernance
10. Étude de cas et exercices

Fil rouge

Une blockchain remplace une autorité de confiance par un protocole : à quelles conditions, à quel coût, et avec quelles hypothèses ?

Problème de confiance, registres distribués, taxonomie

Qu'est-ce qu'une blockchain ?

- **Registre distribué** (DLT) : base de données répliquée sur plusieurs noeuds, sans autorité centrale unique de mise à jour.
- **Blockchain** : registre structuré en blocs d'enregistrements, chaînés par des hachages, en ajout seul (*append-only*).
- L'accord sur l'état du registre est obtenu par un **protocole de consensus**.
- Une blockchain n'est pas synonyme de crypto-monnaie : la monnaie est une application parmi d'autres.
- **Garanties visées** : intégrité, disponibilité, auditabilité, résistance à la censure (selon le type de réseau).
- **Ce qu'elle ne garantit pas** : la véracité des données entrées, la confidentialité par défaut.

Le problème de la double dépense

- Un jeton numérique est copiable : sans autorité, comment empêcher de le dépenser deux fois ?
- Solution classique : un tiers de confiance (banque) tient le registre.
- Solution Nakamoto (2008) : un **ordre total** des transactions, établi par consensus et vérifiable par tous.

Idée centrale

Si tous les noeuds honnêtes s'accordent sur le même ordre des transactions, la seconde dépense est invalide, sans arbitre central.

Repères historiques

Date	Événement
1982–1999	Problème des généraux byzantins (Lamport), PBFT (Castro–Liskov)
1991	Horodatage de documents (Haber–Stornetta)
2008	Livre blanc de Bitcoin (Nakamoto)
2015	Lancement d'Ethereum : contrats intelligents
2016	Hyperledger Fabric, réseaux permissionnés
2022	Ethereum passe en preuve d'enjeu (*the Merge*)
2024+	Régulation MiCA (UE), généralisation des rollups

Taxonomie des blockchains

	Publique sans permission	**Consortium / permissionnée**	**Privée**
Participation	Ouverte	Membres admis	Une organisation
Consensus typique	PoW, PoS	BFT (QBFT, Raft)	Raft, BFT
Confiance requise	Faible entre pairs	Entre membres	Dans l'opérateur
Performances	Limitées	Élevées	Élevées
Exemples	Bitcoin, Ethereum	Hyperledger Besu, Fabric	Registre interne

Deux axes distincts : **lecture** (publique/restreinte) et **écriture/validation** (ouverte/permissionnée).

Propriétés attendues : sûreté et vivacité

- **Sûreté** (*safety*) : deux noeuds honnêtes n'acceptent jamais deux états contradictoires finalisés.
- **Vivacité** (*liveness*) : une transaction valide finit par être incluse.
- **Persistance** : un bloc suffisamment profond ne sera plus remplacé (probabiliste ou déterministe).
- **Résistance à la censure** : un participant honnête ne peut être exclu durablement.
- **Compromis** : en cas de partition réseau, il faut sacrifier la disponibilité ou la cohérence (théorème CAP) ; les protocoles choisissent différemment.

Hachage, arbres de Merkle, signatures, adresses, portefeuilles

Fonctions de hachage dans les blockchains

- Propriétés : résistance aux préimages, aux secondes préimages et aux collisions ; effet d'avalanche.
- **Bitcoin** : SHA-256 appliqué deux fois (SHA256d), RIPEMD-160 pour les adresses.
- **Ethereum** : Keccak-256.
- **Rôles** : lien entre blocs, identifiants de transactions, preuve de travail, arbres de Merkle, dérivation d'adresses.
- **Piège** : le hachage n'est pas un chiffrement ; une donnée à faible entropie hachée reste devinable par énumération.

Arbre de Merkle : exemple détaillé

Transactions a, b, c, d :

- Feuilles : $h_a = H(a),\ h_b = H(b),\ h_c = H(c),\ h_d = H(d)$.
- Niveau 1 : $h_{ab} = H(h_a \| h_b), \quad h_{cd} = H(h_c \| h_d)$.
- Racine : root $= H(h_{ab} \| h_{cd})$ (stockée dans l'en-tête du bloc).

Preuve d'inclusion de c : le vérifieur reçoit $(h_d,\ h_{ab})$ et recalcule $H(H(h_c \| h_d) \| \ldots)$ en respectant l'ordre : root$' = H(h_{ab} \| H(h_c \| h_d))$.
Si root$'$ = root, c appartient au bloc.
Taille : pour n transactions, $\lceil \log_2 n \rceil$ hachages. Exemple : $n = 1024$, $10 \times 32 = 320$ octets.
Nombre impair : Bitcoin duplique le dernier noeud (attention aux collisions de structure, CVE-2012-2459).

Signatures numériques, clés et adresses

- Courbe **secp256k1** avec ECDSA (Bitcoin, Ethereum) ; Schnorr/Taproot et Ed25519 selon les chaînes.
- Clé privée sk : entier aléatoire de 256 bits ; clé publique $PK = sk \cdot G$.
- **Adresse** : empreinte de la clé publique
  - Ethereum : 20 derniers octets de Keccak-256(PK) ;
  - Bitcoin : RIPEMD-160(SHA-256(PK)) encodé (Base58Check, Bech32).
- Une transaction est valide si la signature correspond à l'adresse débitée.

Attention

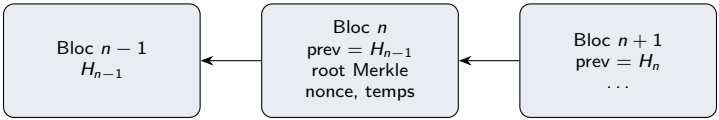
Une signature prouve le contrôle d'une clé, pas l'identité d'une personne. Qui possède la clé possède les fonds : pas de recours en cas de perte.

Portefeuilles et gestion des clés

- **Portefeuille HD** (BIP-32/44) : une graine génère une hiérarchie de clés.
- **Phrase mnémonique** (BIP-39) : 12 à 24 mots encodant la graine.
- Types : logiciel (*hot*), matériel (*cold*), custodial, multisignature, contrats de compte (abstraction de compte).
- **Menaces** : hameçonnage de la phrase, logiciels malveillants, mauvais générateur aléatoire, perte de la graine, signature aveugle de transactions malveillantes.
- **Bonnes pratiques** : portefeuille matériel, multisig pour les montants importants, vérification des données signées.

Blocs, modèles UTXO et comptes, cycle de vie, frais

Structure d'un bloc



En-tête Bitcoin (80 octets) : version, hachage du bloc précédent, racine de Merkle, horodatage, cible (`nBits`), nonce.

Modifier une transaction change la racine, donc le hachage du bloc, donc tous les blocs suivants.

Modèles UTXO et comptes : exemple

UTXO (Bitcoin) : Alice possède un UTXO de 5. Elle paie 2 à Bob avec 0,1 de frais :

- Entrée : UTXO de 5 (détruit, signé par Alice).
- Sorties : 2 pour Bob, 2,9 de monnaie rendue à Alice. Frais $= 5 - (2 + 2{,}9) = 0{,}1$.

Comptes (Ethereum) : état global $\{\text{adresse} \mapsto (\text{solde}, \text{nonce}, \text{code}, \text{stockage})\}$.

- Transaction : $(\text{nonce} = 7,\ \text{to} = \text{Bob},\ \text{value} = 2,\ \ldots)$, signée par Alice.
- Le nonce empêche le rejeu et impose l'ordre des transactions d'un compte.

	UTXO	**Comptes**
Parallélisme	Facile	Plus délicat
Contrats complexes	Limité	Naturel
Confidentialité	Meilleure (adresses multiples)	Adresse réutilisée

Cycle de vie d'une transaction

1. **Création et signature** dans le portefeuille.
2. **Diffusion** aux pairs ; validation locale (signature, solde, nonce).
3. **Mempool** : file d'attente des transactions non confirmées.
4. **Sélection** par un producteur de bloc (mineur ou validateur), en priorité selon les frais.
5. **Inclusion** dans un bloc proposé, propagation.
6. **Confirmations** : chaque bloc suivant augmente la profondeur ; la finalité dépend du consensus.

Une transaction peut être remplacée (RBF, même nonce avec frais plus élevés), abandonnée ou censurée tant qu'elle n'est pas finalisée.

Frais et marché des frais

- Les frais protègent contre le spam et rémunèrent les producteurs de blocs.
- **Bitcoin** : frais par octet virtuel ; l'espace de bloc est limité.
- **Ethereum (EIP-1559)** : frais = gas utilisé $\times$ (base fee + pourboire) ; la base fee est brûlée et ajustée selon le remplissage du bloc.
- **Exemple** : un transfert simple consomme 21 000 gas ; avec base fee de 20 gwei et pourboire de 2 gwei, frais $= 21\,000 \times 22 = 462\,000$ gwei $= 0{,}000462$ ETH.
- **Risque** : congestion, hausse des frais, files d'attente.

Preuve de travail, preuve d'enjeu, tolérance byzantine, finalité

Le problème du consensus

- Noeuds distants, réseau asynchrone ou partiellement synchrone, certains noeuds **byzantins** (fautifs, malveillants).
- Objectif : accord sur une même séquence de blocs (sûreté) et progrès (vivacité).
- **Résultats d'impossibilité** :
  - FLP (1985) : pas de consensus déterministe garanti en asynchrone avec une panne ;
  - BFT : $n \geq 3f + 1$ pour tolérer f noeuds byzantins.
- **Modèle d'adversaire** : fraction de puissance de calcul, d'enjeu ou de validateurs contrôlée.
- **Résistance aux Sybil** : coût d'entrée (calcul, mise, admission) pour éviter les identités multiples gratuites.

Preuve de travail (PoW)

- Trouver un `nonce` tel que $H(\text{en-tête}) < \text{cible}$.
- Le premier mineur qui trouve propage le bloc ; les autres le valident (vérification peu coûteuse).
- **Règle de chaîne** : la chaîne de plus grand travail cumulé.
- **Bitcoin** : un bloc environ toutes les 10 minutes, ajustement de la difficulté tous les 2016 blocs, récompense divisée par 2 tous les 210 000 blocs (offre maximale de 21 millions).
- **Sécurité** : repose sur la majorité honnête de puissance de calcul.
- **Limites** : consommation énergétique, centralisation par pools et matériel spécialisé, finalité probabiliste.

PoW : exemple chiffré

Difficulté : exiger k bits nuls en tête du hachage revient à $P(\text{succès par essai}) = 2^{-k}$.

- $k = 20$: en moyenne $2^{20} \approx 10^6$ essais.
- À 10^{12} hachages par seconde, le temps espéré est $2^{20}/10^{12} \approx 1\,\mu$s.
- Pour un bloc toutes les 600 s à un taux de hachage global R, la difficulté est réglée de sorte que $\mathbb{E}[\text{essais}] \approx 600 \cdot R$.

Propriété : la recherche est sans mémoire (loi géométrique) ; un mineur avec fraction q de la puissance trouve le prochain bloc avec probabilité q.
Remarque : si R double, le temps inter-blocs tombe à 300 s jusqu'au prochain ajustement.

Preuve d'enjeu (PoS)

- Le droit de proposer et valider dépend de l'**enjeu bloqué** (*stake*).
- **Ethereum (Gasper = Casper FFG + LMD-GHOST)** : créneaux de 12 s, époques de 32 créneaux, 32 ETH par validateur, finalité après deux époques (environ 13 minutes).
- **Sanctions** : *slashing* en cas de double signature ; pénalités d'inactivité.
- **Avantages** : consommation énergétique très faible, finalité économique.
- **Risques** : concentration de l'enjeu, services de staking liquide, attaques à longue portée, *nothing at stake* (atténué par le slashing), censure par les validateurs.

Consensus BFT : exemple avec $n = 4$

Tolérance : $n \geq 3f + 1$, donc $f = 1$ pour $n = 4$. Quorum $= 2f + 1 = 3$.

1. **Proposition** : le leader envoie un bloc B aux validateurs.
2. **Préparation** : chaque validateur diffuse son vote pour B ; à 3 votes valides, il est *préparé*.
3. **Validation** : chaque validateur diffuse *commit* ; à 3 commits, le bloc est **finalisé**.

Pourquoi 3 ? Deux quorums de 3 parmi 4 se recoupent en au moins $2 \cdot 3 - 4 = 2$ validateurs, dont au moins 1 honnête : deux blocs contradictoires ne peuvent être finalisés.
Changement de leader si le leader est défaillant ou byzantin (timeout). **Implémentations** : PBFT, Tendermint, IBFT 2.0 et QBFT (Hyperledger Besu).
Limites : communication $O(n^2)$, ensemble de validateurs connu.

Comparaison des familles de consensus

	PoW	**PoS**	**BFT**
Participation	Ouverte	Ouverte (enjeu)	Ensemble connu
Finalité	Probabiliste	Économique/explicite	Immédiate
Tolérance	$< 50\,\%$ du calcul	$< 1/3$ ou $< 1/2$ de l'enjeu	$f < n/3$
Débit	Faible	Moyen	Élevé
Énergie	Élevée	Faible	Faible
Passage à l'échelle des validateurs	Excellent	Bon	Limité

Pair à pair, noeuds, règle de chaîne, double dépense

Réseau pair à pair et types de noeuds

- Diffusion par *gossip* : chaque noeud relaie transactions et blocs à ses voisins.
- **Types** : noeud complet (valide tout), noeud d'archive, client léger (en-têtes + preuves de Merkle), validateur/mineur.
- **Synchronisation** : téléchargement des en-têtes, puis des blocs, vérification de l'état.
- **Menaces réseau** : attaque Eclipse (isoler un noeud), partitionnement, déni de service, centralisation de l'infrastructure (hébergeurs, relais).
- **Parades** : diversité de pairs, limites de connexions, listes d'amorçage multiples.

Forks, réorganisations et règle de chaîne

- **Fork accidentel** : deux blocs valides au même niveau, résolus par la règle de chaîne (PoW : plus de travail ; PoS : LMD-GHOST).
- **Réorganisation** (*reorg*) : remplacement de blocs récents ; les transactions peuvent revenir dans le mempool.
- **Soft fork** : durcissement des règles, compatible avec les anciens noeuds.
- **Hard fork** : règles incompatibles, scission possible (ex. Ethereum / Ethereum Classic).
- **Conséquence applicative** : attendre une profondeur ou une finalité adaptée à la valeur de l'opération.

Probabilité de double dépense (Nakamoto)

Attaquant avec fraction q de la puissance, marchand attendant z confirmations. Probabilité que l'attaquant rattrape un retard de z blocs :

$$P(q,z) = \begin{cases} 1 & q \geq 0{,}5 \\ 1 - \sum_{k=0}^{z} \frac{\lambda^k e^{-\lambda}}{k!} \left(1 - (q/p)^{z-k}\right) & \text{sinon} \end{cases} \qquad p = 1-q,\ \lambda = z\,\frac{q}{p}$$

z	1	5	10
$q = 0{,}1$	0,2046	0,0009	$< 10^{-5}$
$q = 0{,}3$	0,6278	0,1774	0,0417

Lecture : plus l'attaquant est puissant, plus il faut de confirmations ; au-dessus de 50 % il réussit presque sûrement.

Modèle d'exécution, EVM, gas, standards, oracles

Qu'est-ce qu'un contrat intelligent ?

- Programme déployé sur la blockchain, à une adresse, avec son état persistant.
- Exécuté **de façon déterministe** par chaque noeud, déclenché par une transaction ou un autre contrat.
- **Propriétés** : code public, exécution vérifiable, immuable une fois déployé (sauf mécanismes de mise à jour par proxy).
- **Ce n'est pas** un contrat juridique : la valeur légale dépend du cadre applicable.
- **Cas d'usage** : jetons, finance décentralisée (DeFi), registres, escrow, gouvernance, contrôle d'accès.

L'EVM et le gas

- **EVM** : machine virtuelle à pile, mots de 256 bits, jeu d'opcodes, stockage clé-valeur persistant.
- Chaque opcode a un coût en **gas** : le gas borne l'exécution et empêche les boucles infinies.
- **Coûts indicatifs** : écriture de stockage nettement plus chère que le calcul ou la mémoire ; transfert simple 21 000 gas.
- **Limite de gas par bloc** : plafonne le travail par bloc.
- **Déterminisme** : pas d'accès direct à l'heure réelle, au réseau ou à de l'aléa fiable.
- Autres machines : WASM (Polkadot, CosmWasm), Move (Sui, Aptos), chaincode (Fabric).

Exemple : contrat de séquestre simplifié

```
// Solidity (schema simplifie, non audite)
contract Escrow {
  address public buyer; address public seller; bool public released;
  constructor(address _seller) payable { buyer = msg.sender; seller = _seller; }
  function release() external {
    require(msg.sender == buyer, "only buyer");
    require(!released, "done");
    released = true; // effet avant interaction
    (bool ok, ) = seller.call{value: address(this).balance}("");
    require(ok, "transfer failed");
  }
}
```

Points d'attention : contrôle d'accès, ordre effets–interactions, gestion des échecs d'appel, absence de délai de secours (fonds bloqués si l'acheteur disparaît).

Standards de jetons et d'interfaces

Standard	Objet	Remarque
ERC-20	Jetons fongibles (`transfer`, `approve`)	Risque des autorisations illimitées
ERC-721	Jetons non fongibles	Métadonnées souvent hors chaîne
ERC-1155	Multi-jetons	Efficace pour les lots
ERC-4337	Abstraction de compte	Comptes programmables, récupération
EIP-1559	Marché des frais	Base fee brûlée

Standards généraux : ISO 22739 (vocabulaire), ISO/TC 307, NIST IR 8202 (introduction).

Oracles et limites du modèle

- La chaîne ne connaît que son propre état : les données externes (prix, événements, identité) passent par des **oracles**.
- **Problème de l'oracle** : la garantie de la chaîne ne s'étend pas à la donnée entrée.
- **Parades** : agrégation de plusieurs sources, signatures de fournisseurs, moyennes pondérées dans le temps (TWAP), mécanismes de contestation, éléments matériels de confiance (TEE).
- **Autres limites** : coût du calcul, confidentialité par défaut inexistante, difficulté de corriger un bug une fois déployé, valeur légale incertaine.

Menaces consensus, contrats, MEV, clés et ponts

Taxonomie des attaques

Niveau	Attaque	Parade
Consensus	51 %, minage égoïste, long-range	Décentralisation, profondeur, checkpoints
Réseau	Eclipse, Sybil, DoS	Diversité de pairs, limites
Contrats	Réentrance, dépassements, contrôle d'accès, manipulation d'oracle	Audits, tests, vérification formelle
Économie	MEV, sandwich, flash loan	Mécanismes anti-MEV, slippage
Utilisateur	Hameçonnage, clés volées	Matériel, multisig
Infrastructure	Ponts, clés d'administration	Minimiser la confiance, rotation

Réentrance : exemple vulnérable

```
// VULNERABLE
function withdraw() external {
  uint amt = balances[msg.sender];
  (bool ok, ) = msg.sender.call{value: amt}(""); // appel externe d'abord
  require(ok);
  balances[msg.sender] = 0; // effet trop tard
}
// CORRIGE : motif checks-effects-interactions
function withdraw() external nonReentrant {
  uint amt = balances[msg.sender];
  balances[msg.sender] = 0; // effet avant interaction
  (bool ok, ) = msg.sender.call{value: amt}("");
  require(ok);
}
```

Un contrat attaquant rappelle `withdraw` depuis sa fonction de réception avant la mise à zéro, et vide les fonds (cas historique : The DAO, 2016).

MEV, front-running et ordre des transactions

- **MEV** (*maximal extractable value*) : gain obtenu en choisissant, insérant ou censurant des transactions.
- **Exemples** : *front-running*, *sandwich* sur un échange décentralisé, arbitrage, liquidations.
- **Conséquence** : le mempool public révèle les intentions ; l'ordre n'est pas neutre.
- **Parades** : relais privés, séparation proposeur/constructeur (PBS), *commit-reveal*, enchères par lots, limites de glissement.
- **Enjeu de conception** : l'ordonnancement est une surface d'attaque économique, pas seulement technique.

Compromission de clés et ponts : leçons

- La majorité des pertes proviennent des **clés et des contrats**, pas de la cryptographie de base.
- **Ponts inter-chaînes** : concentrent de grands dépôts derrière peu de signataires ; cibles fréquentes d'attaques majeures.
- **Clés d'administration** : mise à jour de contrats par proxy, pause, rôles privilégiés : chaque pouvoir est une porte d'entrée.
- **Bonnes pratiques** : multisig ou MPC, délai (*timelock*) avant les changements, séparation des rôles, audits indépendants, surveillance et plan de réponse aux incidents.

8. Passage à l'échelle

Trilemme, rollups, sharding, interopérabilité

Le trilemme de la blockchain

- Difficulté d'obtenir simultanément **décentralisation**, **sécurité** et **passage à l'échelle**.
- **Goulots** : bande passante, stockage de l'état, exécution séquentielle, vérification par tous les noeuds.
- **Voies** :
  - augmenter la taille des blocs (centralisation) ;
  - **couche 2** : exécuter hors couche 1, vérifier ou ancrer sur couche 1 ;
  - **sharding** : fragmenter l'état ou les données ;
  - chaînes spécialisées.
- L'approche dominante sur Ethereum : **rollups** pour l'exécution, couche 1 pour la sécurité et la disponibilité des données.

Rollups : optimistes vs preuves à divulgation nulle

	Optimistic rollup	**ZK rollup**
Principe	Suppose les lots corrects, fenêtre de contestation	Preuve de validité vérifiée sur couche 1
Retrait vers L1	Plusieurs jours (contestation)	Rapide après vérification de la preuve
Coût de calcul	Faible	Génération de preuve coûteuse
Compatibilité EVM	Excellente	En progrès
Hypothèse de sécurité	Au moins un observateur honnête	Solidité de la preuve, setup éventuel

Risques communs : séquenceur centralisé, clés de mise à jour, disponibilité des données.

Interopérabilité entre chaînes

- **Ponts** : verrouillage/émission, passerelles à validateurs, clients légers sur chaîne.
- **Protocoles** : IBC (Cosmos), messageries inter-chaînes, échanges atomiques par *hash time-locked contracts* (HTLC).
- **Hypothèses de confiance** : l'interopérabilité hérite de la sécurité de la moins sûre des chaînes ou du pont.
- **Critères d'évaluation** : qui valide ? quel quorum ? quelles preuves ? quel délai de contestation ? quels pouvoirs d'administration ?

Pseudonymat, preuves ZK, RGPD, MiCA, évolution du protocole

Pseudonymat et traçabilité

- Les adresses sont **pseudonymes**, non anonymes : toutes les transactions sont publiques et liées.
- **Désanonymisation** : heuristiques de regroupement (propriété commune des entrées), analyse de graphe, liens avec les plateformes d'échange (KYC), métadonnées réseau.
- **Parades** : adresses jetables, CoinJoin, adresses furtives, réseaux de mélange.
- **Chaînes de confidentialité** : Zcash (zk-SNARK), Monero (signatures en anneau, montants confidentiels).
- **Tension** : confidentialité des utilisateurs vs obligations de lutte contre le blanchiment.

Preuves à divulgation nulle et blockchain

- **Principe** : prouver qu'un calcul est correct sans révéler les entrées (ou en vérifiant plus vite que le calcul).
- **Familles** : zk-SNARK (Groth16, PLONK), zk-STARK (sans setup de confiance, preuves plus grandes).
- **Usages** : confidentialité (Zcash), passage à l'échelle (ZK rollups), identité (preuves de prédicats), preuves de conformité.
- **Limites** : coût de génération de preuve, complexité des circuits, bugs de circuit (sécurité), setup de confiance pour certains schémas.

RGPD, MiCA et cadre juridique

- **RGPD** : minimisation, finalité, droit à l'effacement (art. 17) en tension avec l'immutabilité ; identifier le responsable de traitement dans un réseau distribué.
- **Bonne pratique** : ne pas écrire de données personnelles sur la chaîne ; stocker hors chaîne et n'ancrer que des engagements non réversibles.
- **MiCA** (UE) : cadre pour les crypto-actifs et leurs prestataires.
- **LAB-FT** : obligations KYC/AML pour les prestataires (règle de voyage).
- **Qualification des jetons** : monnaie, instruments financiers, jetons utilitaires ; dépend de la juridiction.
- Consulter les lignes directrices de l'EDPB sur la blockchain.

Gouvernance et évolution des protocoles

- Qui décide des changements ? Développeurs, mineurs/validateurs, utilisateurs, détenteurs de jetons.
- **Gouvernance hors chaîne** : propositions d'amélioration (BIP, EIP), consensus social, coordination des clients.
- **Gouvernance sur chaîne** : votes pondérés par jetons, DAO ; risques de ploutocratie, d'apathie et d'attaque par achat de voix.
- **Réseaux de consortium** : règles d'admission, vote des membres, administration par multisig.
- **Durabilité** : empreinte énergétique du PoW vs PoS, évaluation sur cycle de vie.

Faut-il une blockchain ? Traçabilité d'une chaîne d'approvisionnement

Arbre de décision : faut-il une blockchain ?

1. Faut-il stocker un état partagé ? *Non* $\Rightarrow$ base de données classique.
2. Plusieurs écrivains ? *Non* $\Rightarrow$ base de données classique.
3. Les écrivains se font-ils confiance mutuellement, ou y a-t-il un tiers de confiance disponible ? *Oui* $\Rightarrow$ base de données.
4. Faut-il une vérification publique ou une résistance à la modification ? *Oui* $\Rightarrow$ DLT envisageable.
5. Les données sont-elles sensibles ? *Oui* $\Rightarrow$ hors chaîne + ancrage de hachages.
6. Réseau public ou permissionné ? Selon les besoins de participation ouverte et de performances.

Conclusion

Une blockchain est justifiée par un défaut de confiance entre parties, pas par un effet de mode. Évaluer coûts, latence, gouvernance et régulation.

Cas : traçabilité d'une chaîne d'approvisionnement alimentaire

- **Acteurs** : producteurs, transformateurs, transporteurs, distributeurs, autorité sanitaire, consommateurs.
- **Architecture** : réseau de consortium (ex. Besu en QBFT) ; chaque acteur gère un validateur.
- **Sur chaîne** : événements de lot (identifiant, étape, horodatage, hachage du document), droits d'écriture par rôle (smart contract).
- **Hors chaîne** : certificats, mesures de capteurs, documents commerciaux, données personnelles.
- **Flux** : capteur/opérateur signe l'événement $\rightarrow$ contrat vérifie le rôle $\rightarrow$ événement inscrit $\rightarrow$ le consommateur vérifie l'historique par QR code.
- **Problème de l'oracle** : un capteur ou opérateur peut mentir ; la blockchain garantit l'historique, pas la vérité initiale.

Attaques sur le cas et mesures

Attaque	**Effet**	**Mesure**
Saisie frauduleuse (garbage in)	Lot faussement certifié	Capteurs signés, audits, sanctions, recoupements
Collusion de validateurs	Réécriture de l'historique	Seuil $3f + 1$, diversité des membres, ancrage externe
Vol de clé d'un opérateur	Faux événements	Matériel, rotation, révocation de rôle
Fuite commerciale	Concurrents voient les flux	Hachages, canaux privés, chiffrement hors chaîne
Contrat bogué	Droits mal appliqués	Audit, tests, mise à jour gouvernée
Déni de service	Écritures bloquées	Redondance, quotas, mode dégradé

Arbitrages de conception

Axe	Option A	Option B
Type de réseau	Public (neutralité, coûts)	Consortium (performances, contrôle)
Consensus	PoS public (ouverture)	BFT (finalité immédiate)
Données	Tout sur chaîne (transparence)	Ancrage de hachages (vie privée)
Mise à jour des contrats	Immuable (confiance)	Proxy (correction possible)
Passage à l'échelle	Couche 1 seule	Rollup (coûts, complexité)

Aucune option dominante : relier chaque choix aux menaces, à la régulation et à la gouvernance.

Exercices (1/2) : analyse

1. Calculer la racine de Merkle de 5 transactions selon la règle de Bitcoin (duplication du dernier noeud) et décrire une preuve d'inclusion de la 3e.
2. Un mineur détient 30 % du taux de hachage. Combien de confirmations un marchand doit-il attendre pour que le risque soit inférieur à 1 % ? (utiliser le tableau ou la formule)
3. Montrer pourquoi $n = 3f$ validateurs ne suffisent pas pour garantir la sûreté d'un protocole BFT.
4. Identifier la vulnérabilité dans un contrat qui met à jour le solde *après* l'appel externe ; proposer deux corrections.
5. Comparer finalité, coût d'attaque et centralisation entre PoW, PoS et QBFT.

Exercices (2/2) : conception d'un système sur blockchain

Énoncé. Un consortium de cinq hôpitaux veut partager la preuve d'intégrité et l'horodatage de comptes rendus d'examens.

Livrables :

1. Justifier (ou non) l'usage d'une blockchain avec l'arbre de décision.
2. Choisir le type de réseau, le consensus et le nombre de validateurs.
3. Définir ce qui est on-chain et off-chain, au regard du RGPD.
4. Concevoir le contrat de contrôle d'accès et les rôles.
5. Établir le modèle de menaces (au moins six menaces) et les mesures.
6. Définir la gouvernance (admission, retrait, mises à jour).
7. Évaluer les coûts, la latence et les limites.

Questions de discussion

- La décentralisation est-elle une propriété mesurable ? Par quels indicateurs ?
- L'immutabilité est-elle une qualité ou un risque (erreurs, contenu illicite, effacement) ?
- La finalité probabiliste suffit-elle pour des paiements de forte valeur ?
- Les rollups déplacent-ils la confiance vers les séquenceurs ?
- Une blockchain de consortium est-elle autre chose qu'une base de données distribuée ?

Synthèse

- La blockchain est un **registre répliqué en ajout seul** dont l'ordre est fixé par consensus.
- La **cryptographie** garantit l'intégrité et l'authenticité des écritures, pas la véracité des données.
- Le **consensus** (PoW, PoS, BFT) définit le modèle d'adversaire, la finalité et les performances.
- Les **contrats intelligents** étendent le registre en machine à états, avec de nouvelles surfaces d'attaque.
- La **sécurité** dépend surtout des clés, des contrats, de l'ordonnancement et des ponts.
- La **vie privée**, la **régulation** et la **gouvernance** déterminent si le système est déployable.
- Toujours se demander si une blockchain est nécessaire.

Références

- Nakamoto S., *Bitcoin : A Peer-to-Peer Electronic Cash System*, 2008.
- Buterin V., *Ethereum White Paper*, 2014 ; Wood G., *Ethereum Yellow Paper*.
- Castro M., Liskov B., *Practical Byzantine Fault Tolerance*, OSDI 1999.
- Lamport L., Shostak R., Pease M., *The Byzantine Generals Problem*, 1982.
- Fischer M., Lynch N., Paterson M., *Impossibility of Distributed Consensus with One Faulty Process*, 1985.
- Buterin V., Griffith V., *Casper the Friendly Finality Gadget*, 2017.
- Antonopoulos A., *Mastering Bitcoin* ; Antonopoulos A., Wood G., *Mastering Ethereum*.
- NIST IR 8202, *Blockchain Technology Overview* ; ISO 22739.
- Règlement MiCA ; RGPD ; lignes directrices EDPB sur la blockchain.
- EIP-1559, ERC-20, ERC-721, ERC-4337 ; BIP-32, BIP-39, BIP-44.